

OPERATION IRON RAVEN

Executive Summary Report — Non-Technical Leadership Briefing

Prepared by	Daniyal Ahmed
Course	Offensive Security Operations II — CIP-A105
Assessment	CTF 1 — Competency Exam
Date	16–17 September 2026
Classification	Training Use Only

Purpose

An authorised penetration test was conducted against a standalone lab server (OPFOR-01) to evaluate its security posture, identify exploitable weaknesses, and document the business risk those weaknesses represent. The test was performed in a fully isolated virtual network and did not affect any live or production systems.

Outcome

FULL COMPROMISE — All Four Mission Objectives Achieved

The target was completely compromised. The operator advanced from having no access to obtaining unrestricted root-level administrative control over the server. All four challenge flags were recovered, confirming access to every tier of the system — from the public web interface through to the superuser account.

How the System Was Compromised

In non-technical terms, the attack unfolded in four steps:

- **Step 1 — Gaining a Foothold:** A web component on the server (the contact form mailer) was found running an outdated version with a publicly known critical flaw. Exploiting this

flaw allowed a hidden remote-control program to be silently installed on the server without any login credentials.

- **Step 2 — Harvesting Credentials:** Once inside, configuration files on the server were found to contain the database administrator username and password stored in plain text — readable by anyone with access to those files.
- **Step 3 — Escalating Privileges:** Using those credentials, the operator accessed the database service. Because the database program was incorrectly configured to run with full operating system administrator privileges, a specialised technique allowed the operator to run commands as the system's root (superuser) account.
- **Step 4 — Full Administrative Control:** Root access was confirmed and all four hidden proof files were read from protected locations across the filesystem, including the /root/ administrator home directory.

Critical Risks Identified

Risk	Business Impact	Priority
Outdated mail component with a known public exploit (PHPMailer 5.2.16 — CVE-2016-10033)	Any visitor can take complete control of the web server without logging in.	CRITICAL
Database administrator password stored in plain text in application files	Anyone who gains web server access can immediately access the entire database.	HIGH
Database service running with full operating-system administrator rights	Database compromise directly translates to complete system takeover.	CRITICAL
Internal file directory exposed on the web server (no access restriction)	Software versions and internal library files are visible to any visitor, enabling targeted attacks.	MEDIUM

Recommended Immediate Actions

- Update the mail library (PHPMailer) to the latest patched version immediately.
- Remove the database password from the application configuration file and store it securely.

- Reconfigure the database service to run as a dedicated low-privilege account, not the system administrator.
- Disable web server directory browsing so internal files are not visible to the public.
- Conduct a full audit of all third-party software components for known vulnerabilities.

Conclusion

The target exhibited multiple severe and compounding security deficiencies that enabled complete compromise in a single session. Each individual vulnerability was serious; together they formed an attack chain that required no privileged access or inside knowledge to execute. Prompt remediation of the critical and high-priority findings is essential.

Prepared by: Daniyal Ahmed | **Course:** Offensive Security Operations II — CIP-A105 |
Date: 16 September 2026